

Descripción Técnica - Identity Provider

2023-07

Conceptos importantes.....	2
OAuth.....	2
OpenID Connect (OIDC).....	2
SSO (Single Sign-On).....	2
Identity Provider (Proveedor de Identidad).....	3
Relación entre conceptos de identidad.....	4
Identity Provider (IdP) - Implementación.....	5
Verificación de usuario.....	6
OIDC.....	6
Bearer token.....	8
Inicio de sesión con certificado.....	10
Administración de permisos.....	10
Requerimientos de servidor.....	13
Base de datos.....	13
LDAP - IdP.....	13
Monitoreo y Auditoría.....	14

Conceptos importantes

OAuth

OAuth es un estándar abierto para autorización que permite a las aplicaciones de terceros obtener acceso limitado a un servicio web, ya sea en nombre de un propietario de recurso o permitiendo al tercer servicio para obtener acceso en su propio nombre. Es decir, permite a los usuarios dar permisos específicos a aplicaciones mientras protege sus credenciales de inicio de sesión.

OpenID Connect (OIDC)

OpenID Connect es una capa de identidad que se construye sobre el protocolo OAuth 2.0. A diferencia de OpenID 2.0, que solo proporciona mecanismos para la autenticación, OpenID Connect permite a los clientes, incluyendo aplicaciones web, móviles y de JavaScript, solicitar y recibir información sobre sesiones de autenticación y usuarios finales.

OpenID Connect permite al cliente obtener un ID token, que contiene información sobre el usuario, como el nombre de usuario, la imagen de perfil, y más.

Este ID token es un objeto JSON Web Token (JWT) que está firmado digitalmente por el servidor de autorización. Una vez que se recibe el token, el cliente puede validar el token y extraer información sobre el usuario. Esta capa adicional proporciona una forma estandarizada de obtener la identidad del usuario y permite una mayor interoperabilidad entre diferentes servicios.

SSO (Single Sign-On)

El Single Sign-On, o SSO, es un método de autenticación que permite a un usuario iniciar sesión en múltiples aplicaciones o sitios web utilizando un solo conjunto de credenciales. Esto reduce la necesidad de recordar múltiples nombres de usuario y contraseñas y aumenta la eficiencia en el proceso de autenticación. SSO puede ser implementado de diversas formas, como con cookies, tokens de seguridad, o certificados.

Identity Provider (Proveedor de Identidad)

Un proveedor de identidad, o IdP, es una entidad que crea, mantiene y gestiona información de identidad para los titulares de cuentas y proporciona servicios de autenticación a otras entidades, como aplicaciones, servicios y sistemas. En un sistema de SSO, el proveedor de identidad es la entidad que verifica la identidad del usuario y proporciona las credenciales para acceder a otros servicios o aplicaciones.

Relación entre conceptos de identidad

Concepto	Relación con otros conceptos	Depende De
Proveedor de Identidad (IdP)	Autentica a los usuarios y provee afirmaciones de identidad a las aplicaciones clientes.	N/A
OIDC (OpenID Connect)	Proporciona autenticación a las aplicaciones clientes utilizando tokens de identidad tras la autenticación del usuario.	Proveedor de Identidad (IdP)
SSO (Single Sign-On)	Utiliza los tokens de identidad generados por OIDC para proporcionar acceso a múltiples aplicaciones sin necesidad de autenticaciones adicionales.	OIDC

Identity Provider (IdP) - Implementación

El proveedor de Identidad usa Keycloak como base. Es una solución de gestión de identidad y acceso de código abierto desarrollada por Red Hat. Se apega a los estándares y es ampliamente usado en diferentes entornos productivos. El IdP expuesto por Firmamex para Chihuahua consiste en una instancia configurada de Keycloak, con Firmamex integrado para identificación por clave pública (cer y key) y con librerías para facilitar su uso.

A través de esta herramienta será posible ver una bitácora de eventos, establecer políticas de contraseña y administrar usuarios. Y con la integración con Firmamex permitirá verificar la identidad de los usuarios usando sus certificados del SAT, realizando la validación de la cadena de emisión hasta el Banco de México. O con los certificados emitidos por el Gobierno de Chihuahua, validando igualmente su cadena de certificación y su vigencia por OCSP.

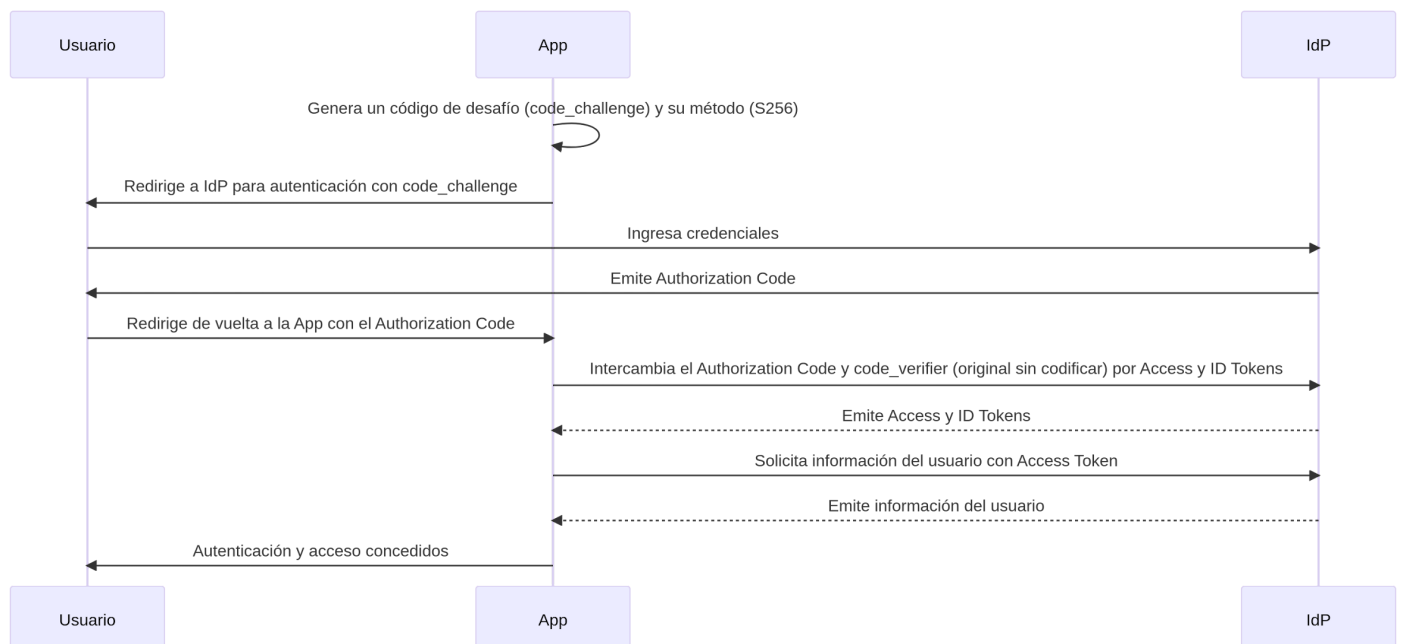
Verificación de usuario

OIDC

Las aplicaciones pueden solicitar un token de acceso desde el frontend usando un flujo de autorización OIDC. El flujo consiste en los siguientes pasos:

1. La Aplicación genera un *code_challenge* a partir de un valor aleatorio llamado *code_verifier*. Este *code_challenge* se crea generando un hash SHA-256 del *code_verifier*.
2. La Aplicación redirige al usuario al IdP para autenticarse. En esta redirección, la Aplicación envía el *code_challenge* al IdP.
3. El usuario ingresa sus credenciales en el IdP.
4. Una vez autenticado, el IdP emite un código de autorización
5. El usuario es redirigido de vuelta a la Aplicación con el código de autorización en la URL.
6. La Aplicación intercambia el código de autorización y el *code_verifier* original con el IdP por los tokens de acceso y de ID
7. El IdP valida que el hash del *code_verifier* proporcionado coincida con el *code_challenge* inicialmente enviado. Si es así, el IdP emite y envía los tokens de acceso y de ID a la Aplicación
8. Con el token de acceso obtenido, la Aplicación puede solicitar información adicional del usuario al IdP.

El diagrama siguiente muestra este flujo:



Para realizar este proceso, se puede utilizar cualquier librería de frontend de OIDC. Aunque recomendamos usar keycloak-js ya que facilita la integración. Ejemplo:

JavaScript

```
const keycloak = new Keycloak({
  url: "https://idp.firmamex.com",
  realm: "ch",
  clientId: "app-documentos",
});

onMount(async () => {
  try {
    await keycloak.init({
      onLoad: 'login-required',
      pkceMethod: 'S256'
    });

    console.log({
      idToken: keycloak.idToken,
      accessToken: keycloak.token
    })
  } catch (e) {
    console.error(e);
  }
});
```

Bearer token

Una vez teniendo el token de acceso generado por OIDC, las aplicaciones de frontend pueden utilizarlo para verificar a los usuarios con aplicaciones de backend por medio de autorización con Bearer Token. Al recibirlo, las aplicaciones de backend deben verificar el token: fecha de expiración, firma, audiencia, permisos, etc.

Por ejemplo, una aplicación en JS puede hacer un request hacia un servicio de backend de la siguiente manera:

JavaScript

```
const resp = await fetch('https://documentos.firmamex/privateEndpoint', {
  headers: {
    Authorization: `Bearer ${keycloak.token}`
  }
})
```

Y la aplicación en backend lo puede verificar al recibirlo (el ejemplo está simplificado, no incluye validaciones necesarias como verificar que el header Authorization no sea null, etc):

Java

```
public Result privateEndpoint(Http.Request request) {

    String token = request.getHeaders().get("Authorization").get().split(" ")[1];

    DecodedJWT res = frmIdP.verify(token);

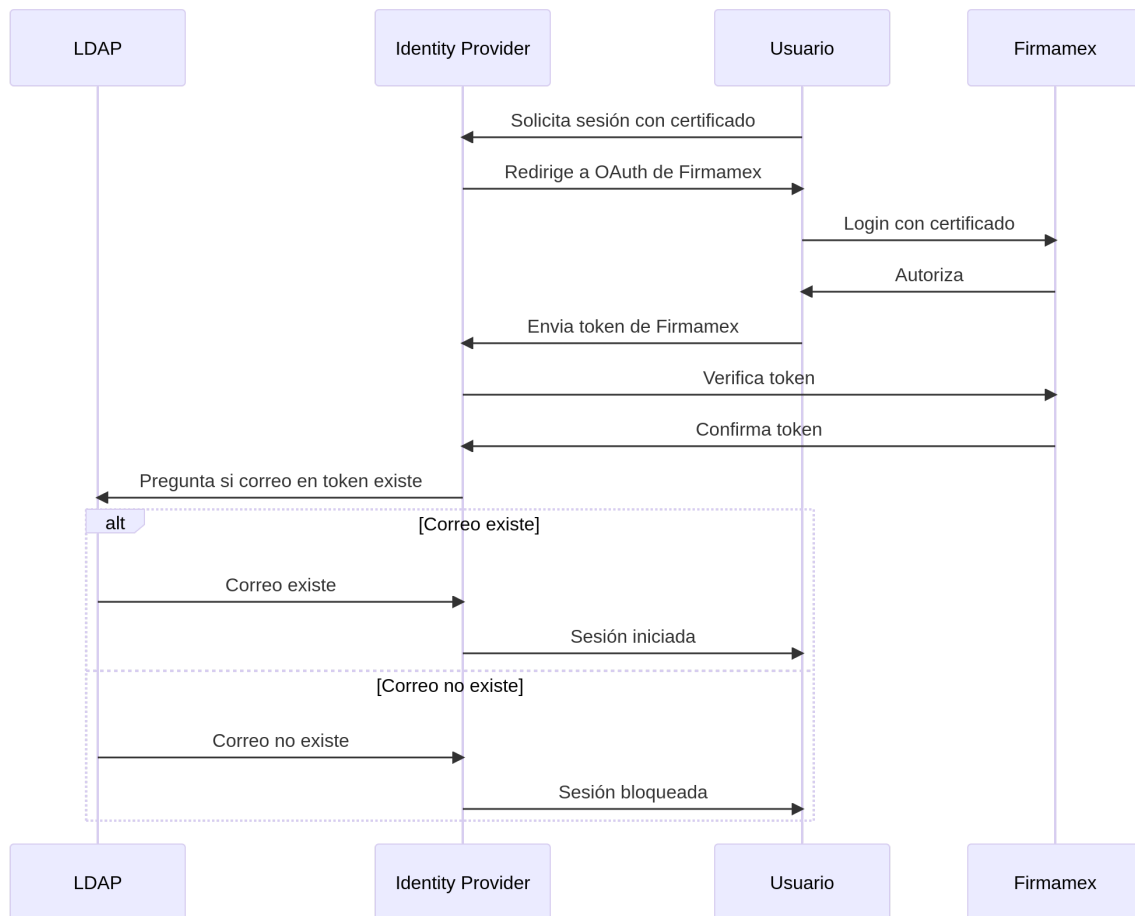
    if(res == null) {
        return unauthorized();
    }

    // usa el token de acceso para contactar al IdP y obtener
    // informacion del usuario
    return ok(frmIdP.getUserData(token));
}
```


En este ejemplo, **FrmxIdP** es una librería auxiliar que facilita el proceso de verificación en el backend. Obtiene los certificados de firma del token de acceso del IdP, verifica la firma en el token y lo decodifica.

Inicio de sesión con certificado

Además del mecanismo de inicio de sesión por correo, es posible iniciar sesión por medio del IdP usando un certificado autorizado. Para esto el IdP hace uso de Firmamex por medio de OAuth para verificar el certificado. El proceso es el siguiente:



1. IdP pregunta si Iniciar sesión con usuario y contraseña o con certificado
2. Si Usuario elige certificado, realiza OAuth de Firmamex
3. IdP verifica que el correo del usuario en el certificado sea el de un usuario existente
4. Si existe lo deja pasar
5. Si no existe, lo bloquea

Administración de permisos

Por medio del IdP es posible controlar los permisos de las diferentes aplicaciones de los usuarios:

1. Se definen roles a nivel general: Los roles pueden ser admin, usuario, lector, etc.
2. Se definen permisos a nivel aplicación: Estos permisos pueden definirse de dos maneras:
 - a. Como rol de aplicación: admin, usuario, lector, etc
 - b. Como permiso de aplicación: escribir-usuarios, ver-usuarios, etc
3. Se relacionan los roles generales con los permisos a nivel aplicación definidos. Cada rol general puede tener una interpretación diferente dentro de cada aplicación
4. Se asignan los roles generales a los diferentes usuarios

Estos roles se podrán ver en el token de sesión generado, en el atributo roles, al completar la verificación de usuario:

```
Unset
{
  "exp": 1691784529,
  "iat": 1691784229,
  "auth_time": 1691782614,
  "jti": "2eb2c68c-69a6-4014-8309-57c702281205",
  "iss": "https://idp.firmamex.com/realms/ch",
  "sub": "475e71dc-03ae-4705-a75b-bbe648a8ceee",
  "typ": "Bearer",
  "azp": "app.com",
  "nonce": "856756b9-1a8c-4b09-8f9b-07fdaf910ada",
  "session_state": "e1253923-d858-4bf1-bab8-337b5ceed913",
  "acr": "0",
  "allowed-origins": [
    "https://app.com",
  ],
  "scope": "openid profile roles email",
  "sid": "e1253923-d858-4bf1-bab8-337b5ceed913",
  "email_verified": false,
  "roles": [
    "user", // caso 1
    "ver-usuarios" // caso 2
  ],
  "preferred_username": "usuario",
  "given_name": "",
  "family_name": ""
}
```

Requerimientos mínimos de servidor

1. Servidor Linux
2. Java 8
3. 512 MB de RAM
4. 1 GB disco duro

Base de datos

Keycloak permite configurarse con diferentes bases de datos, pero para mantener uniformidad con el resto de los servicios ofrecidos (Autoridad Certificadora, Firmamex), recomendamos la utilización de una base de datos MySQL

LDAP - IdP

El IdP puede conectarse a un LDAP para obtener los usuarios. Los usuarios se importarán cuando inicien sesión por primera vez o cuando se acceda su información por medio del IdP

El IdP guarda los datos del usuario, pero no la contraseña. La validación de usuario y contraseña se realiza siempre en el LDAP

Es posible configurar mappers para la importación de los usuarios, de manera que se importen a grupos de usuarios específicos o a roles dependiendo de la información de cada usuario en el LDAP

Grupos: Mapea a grupos dentro del IdP dependiendo de la rama del árbol del LDAP en el que se encuentren asignados

Roles: Mapea roles dependiendo de la rama del árbol del LDAP a roles correspondientes en el IdP.

Monitoreo y Auditoría

Dentro del portal de administración es posible ver registros detallados de eventos, lo que permite rastrear actividades específicas, como inicios de sesión, cambios de contraseña y modificaciones en la configuración

Esta configuración puede realizarse en la sección de RealmSettings, en la pestaña de Events

GeneralLoginEmailThemesKeysEventsLocalizationSecurity defensesSessionsTokensClient policiesUser registration

Event listenersUser events settingsAdmin events settings

Save events ⓘ

☒ On

Expiration ⓘ

Minutes ▾

Save

Revert

Clear user events ⓘ

Clear user events

🔍 Search saved event ty... →

Add saved types

1 - 10 ▾ < >

Event saved type	Description
Login	Login ⓘ
Login error	Login error ⓘ
Register	Register ⓘ
Register error	Register error ⓘ
Logout	Logout ⓘ
Logout error	Logout error ⓘ
Code to token	Code to token ⓘ